Geração e detecção de trojans entre grupos

Arthur Moriggi Pimenta - Nº USP: 9425636 - arthur.moriggi.pimenta@usp.br
Caio Vinícius Ribeiro da Silva - Nº USP: 18083535 - caiovribeiro@usp.br
Roberto Spinelli Filho - Nº USP: 3119088 - rspinelli@usp.br
Disciplina: PCS5917 - IA Adversarial
Professor: Dr. Victor Takashi Hayashi - victor.hayashi@usp.br
Instituição: Universidade de São Paulo - Escola Politécnica

Resumo. Relatamos um desafio entre grupos de geração e detecção de trojans. Produzimos vinte variantes independentes do PicoRV32, dez deliberadamente incorretas e dez candidatas benignas, e enviamos o conjunto com IDs permutados. Na frente de detecção, analisamos estaticamente vinte versões de AES recebidas do grupo E. O grupo autor confirmou vinte acertos, com acurácia de 100%. A análise identificou gatilhos sobre dados e histórico e uma ressalva contratual em amostra benigna. A avaliação do ataque PicoRV32 permanece pendente. Discutimos os resultados da classificação e a contribuição de um ciclo purple team para a revisão entre grupos.

Palavras-chave: Trojans, análise estática, PicoRV32, AES, purple team.

1 Introdução

Alterações de código semelhantes em aparência podem ter efeitos distintos: uma refatoração preserva o contrato funcional, enquanto um trojan introduz uma violação deliberada. Distingui-las exige acompanhar dados, condições e estado, em vez de usar apenas o tamanho do patch ou a região modificada. No desafio da Aula 8 de PCS5917, exercitamos as duas posições: produzir amostras para outro grupo e analisar um conjunto recebido.

Na frente de geração, escolhemos o PicoRV32, núcleo RISC-V em Verilog [1], e produzimos dez alterações deliberadamente incorretas e dez candidatas benignas. Na frente de detecção, recebemos do grupo E vinte versões C++ de AES e sua regra de negócio. A classificação foi realizada por inspeção estática assistida pelo Codex. Posteriormente, o grupo E confirmou o acerto das vinte respostas.

O objetivo é descrever a construção dos conjuntos, a identificação de gatilhos e efeitos, os resultados disponíveis e as lições da interação. A versão é preliminar porque ainda falta o retorno sobre o conjunto PicoRV32 enviado. A classificação do AES já foi confirmada pelo grupo autor.

2 Metodologia

2.1 Duas frentes e contratos distintos

No PicoRV32, cada variante deriva independentemente da mesma referência, identificada pelo commit ef203c2b0a3fb793280f5114941416c425c5b461. O recorte adotado foi RV32I com interface nativa de memória, sem interrupções nem coprocessador. O contrato pretendido abrange resultados arquiteturais, transações de memória, reset, sinalização de trap e progresso da execução. Nas candidatas benignas, buscamos preservar também a temporização externa, sem alterar parâmetros de configuração.

No AES, seguimos o contrato fornecido pelo grupo E, baseado no FIPS 197 [2]. R1 exige correção da cifragem e decifragem; R2, determinismo e independência entre chamadas; R3, exceções para tamanhos inválidos de bloco e chave; R4, ausência de saídas e efeitos observáveis indevidos com verbose desativado; R5, conformidade das variantes, tabelas e expansão de chave; e R6, igualdade com a referência fora dos gatilhos.

Os critérios não são intercambiáveis: no AES, um efeito condicional sobre o retorno já pode invalidar a correção criptográfica. No processador, a comparação precisa considerar sequência de estados, parâmetros e interações de memória. Além disso, nem toda falha deliberada produzida no PicoRV32 depende de um gatilho raro; algumas representam adulterações funcionais diretas para o exercício.

2.2 Geração, anonimização e envio

O Codex apoiou a proposta e a implementação das variantes. Revisamos a lista inicial de benignas para incluir transformações estruturais, como recodificação de estados e aritmética por metades, tornando sua distinção dos trojans dependente de análise funcional. Cada amostra foi isolada em pasta e commit próprios, sem acumular modificações de outras variantes.

Os códigos internos B01-B10 e T01-T10 foram permutados para S01-S20. O ZIP enviado reuniu a referência original, vinte pastas contendo os arquivos modificados, um README com o escopo e um CSV de classificação vazio. O mapeamento e o catálogo internos ficaram fora do pacote. A integridade do ZIP e a correspondência de seus arquivos foram conferidas.

O foco do desafio é distinguir alterações pela leitura e interpretação do código. Os códigos B identificam refatorações concebidas para preservar o contrato; os códigos T identificam alterações deliberadamente incorretas. A organização por região funcional permite contrapor mudanças benignas e maliciosas em componentes semelhantes, reduzindo a utilidade de pistas como o local modificado.

2.3 Detecção das amostras recebidas

Extraímos o campo de código-fonte do CSV do grupo E para vinte arquivos C++, preservando o conteúdo e associando cada arquivo ao identificador A01-A20. A inspeção comparativa localizou mudanças em funções de cifragem, operações de rodada, validação e variáveis persistentes. Como A01 também continha adulteração, foi usada apenas como ponto de comparação textual, nunca como implementação correta de referência.

Para cada mudança suspeita, identificamos a condição de ativação, o efeito produzido e a obrigação do contrato afetada. Comentários que nomeavam trigger e payload ajudaram a localizar trechos, mas a decisão se apoiou nas condições e operações executáveis. A informação de que havia dez amostras por classe serviu como conferência da distribuição; isoladamente, ela não demonstraria a correção dos rótulos.

Registramos as vinte decisões em avaliacao_grupo_e.csv. O método empregado foi a classificação estática: interpretar o efeito de cada mudança e relacioná-lo às regras fornecidas. O resultado foi posteriormente confirmado pelo grupo E, conforme retorno comunicado ao grupo em 11 de novembro de 2026.

3 Resultados e Análises

3.1 Conjunto PicoRV32 produzido

As vinte variantes cobrem controle, caminho de dados e interface de memória. A Tabela 1 registra as dez alterações deliberadas e seus IDs de envio. A tabela contém o gabarito interno, apropriado para este relatório, mas excluído do pacote do desafio.

Tabela 1. Alterações deliberadas no PicoRV32 e seus efeitos sobre o contrato funcional.

Código / envio	Alteração e efeito pretendido
T01 / S16	Inversão do bit menos significativo da soma; resultado aritmético incorreto.
T02 / S17	BEQ aceita igualdade ou comparação menor sem sinal; desvio indevido.
T03 / S05	Inversão do bit inferior do índice de destino; escrita em outro registrador.
T04 / S06	Uso da amostra anterior de rs2; operando defasado.
T05 / S18	Inversão de um bit no caminho de leitura de palavra; load incorreto.
T06 / S19	Rotação em um byte dos dados de store, preservando a máscara.
T07 / S07	Retirada de mem_valid antes da aceitação de uma escrita em espera.
T08 / S01	Uso de PC histórico em resets posteriores, em lugar do endereço configurado.
T09 / S13	Supressão da saída trap; o núcleo pode parar sem sinalizar o erro.
T10 / S08	Retenção no deslocador iterativo ao terminar a contagem; perda de progresso.

T03 depende do banco interno padrão; T10 pressupõe BARREL_SHIFTER=0. Em T09, suprimir a sinalização não significa que a CPU continue executando: o controle pode permanecer no estado de trap. Essas condições delimitam o efeito das alterações e orientam a interpretação do retorno do outro grupo.

Tabela 2. Candidatas benignas do PicoRV32. A intenção é preservar o comportamento da referência.

Código / envio	Transformação
B01 / S11	Permutação da codificação one-hot dos estados.
B02 / S10	Separação dos campos na segunda etapa de decodificação.
B03 / S02	Reconstrução explícita de imediatos e extensão de sinal.
B04 / S04	Soma e subtração por metades, com carry explícito.
B05 / S14	Reformulação das comparações com e sem sinal.
B06 / S20	Seleção de loads com deslocamentos e máscaras.
B07 / S12	Reorganização de dados e máscaras dos stores.
B08 / S09	Cadeia explícita de prioridades do writeback.
B09 / S03	Decomposição booleana do handshake de memória.
B10 / S15	Separação do próximo contador e controle do deslocador.

O conjunto benigno procura evitar uma associação trivial entre patch pequeno e inocuidade. B04, por exemplo, exige acompanhar largura e propagação de carry; B01 muda a representação dos estados sem pretender mudar sua evolução. Essa dificuldade foi uma escolha de construção. Ainda não há medida de dificuldade percebida, taxa de detecção dos trojans ou falsos positivos nas benignas pelo grupo avaliador.

3.2 Trojans identificados no AES

Classificamos como Trojan A01, A03, A06, A07, A08, A10, A11, A12, A14 e A16. A Tabela 3 resume as evidências estáticas. Os índices de bytes começam em zero. Para as adulterações do retorno, a principal obrigação afetada é R1; os casos com histórico afetam também R2.

Tabela 3. Gatilhos e efeitos observados no código recebido do grupo E.

ID	Gatilho e efeito
A01	A cada 256 chamadas válidas, XOR 0x01 no byte 0 do ciphertext.
A03	Chave de 16 bytes com extremos zero: copia seus quatro primeiros bytes para os quatro últimos da saída.
A06	Plaintext simétrico sob espelhamento de posições e reversão dos bits de cada byte: XOR 0x80 no byte 7.
A07	Na rodada 5, após ShiftRows, state[0][0] igual a zero: omite MixColumns.
A08	Plaintext com extremos zero e chave de 16 bytes: XOR do primeiro byte da chave no byte 0 da saída.
A10	Na milésima chamada válida, XOR 0x01 no byte 15.
A11	Plaintext e chave de 16 bytes terminam em 0xFF: lança exceção para bloco válido.
A12	Plaintext começa com DE AD: XOR 0x01 no byte 0 da saída.
A14	Chave com no máximo quatro bits iguais a 1: retorna dezesseis bytes zero.
A16	Terceira repetição consecutiva do mesmo plaintext: XOR 0xFF no byte 0.

A01, A10 e A16 mantêm estado static em encrypt, compartilhado entre instâncias. Assim, o mesmo par de plaintext e chave pode produzir respostas distintas conforme o histórico, contrariando R2. Em A16, a sequência compara apenas o plaintext, independentemente da chave, e o teste é exatamente a terceira repetição, não todas as repetições seguintes.

A03 expõe diretamente parte da chave no retorno, além de adulterar a cifragem. A08 introduz uma dependência indevida de um byte da chave; seu XOR não altera a saída quando esse byte é zero. A condição pode ser alcançada sem efeito visível nessa situação, o que deve ser considerado na escolha de testes. A07 viola também R5 ao remover uma operação de rodada.

3.3 Amostras classificadas como inócuas

Classificamos as outras dez como Inocuo no CSV. A Tabela 4 apresenta as transformações identificadas. Diferentemente do conjunto PicoRV32 produzido, várias mudanças benignas recebidas eram pequenas e localizadas.

Tabela 4. Alterações classificadas como inócuas no AES.

ID	Evidência da inspeção
A02	Função auxiliar gf_multiply retorna a mesma multiplicação a * b.
A04	Inclusão de const em cópias locais e comentários.
A05	Tupla e decomposição estruturada preservam os quatro operandos da coluna.
A09	Exceção adicional para variante AES desconhecida; variantes válidas preservadas.
A13	Inclusão de comentários de documentação.
A15	Literais substituídos por constantes nomeadas com os mesmos valores.
A17	Assertions de invariantes, com ressalva para entradas inválidas.
A18	Alterações de indentação.
A19	Renomeação de variáveis locais.
A20	Coeficientes de quatro posições passam de vector para array, mantendo valores e rotação.

Em A17, observamos uma ressalva: o assert de tamanho pode encerrar o processo antes da exceção exigida por R3 para entradas inválidas. Mantivemos o rótulo inócuo, depois confirmado pelo grupo E, por se tratar de uma verificação defensiva. O caso evidencia a importância de distinguir a classe atribuída no desafio de uma discussão sobre o contrato de entrada.

3.4 Resultado confirmado da classificação

O grupo E confirmou que acertamos todas as vinte respostas. Considerando Trojan como classe positiva, obtivemos VP=10, VN=10, FP=0 e FN=0. A acurácia foi (VP+VN)/20 = 100%; precisão, revocação e F1 para Trojan também foram 100%. Não houve divergências entre nossos rótulos e o gabarito segundo esse retorno.

O resultado mede a concordância da classificação com o gabarito do grupo autor nesse conjunto de vinte casos. A distribuição equilibrada e os comentários indicativos de gatilhos facilitaram a organização da análise. Portanto, os 100% descrevem o desempenho neste desafio, sem estabelecer a mesma taxa para conjuntos maiores ou códigos sem essas pistas.

3.5 Interação entre grupos e purple team

A troca colocou o grupo nas posições de autor e avaliador, em sistemas diferentes. Ao produzir as variantes PicoRV32, procuramos aproximar a complexidade visual das duas classes. Ao receber o AES, o contrato R1-R6 permitiu organizar a revisão por comportamento: correção, histórico, entradas, efeitos e conformidade. Essa experiência mostrou que o contrato e a documentação são parte do instrumento de avaliação.

Os materiais também influenciaram a dificuldade. No pacote produzido, ocultamos o mapeamento dos IDs e fornecemos a referência original. No conjunto AES, comentários nomeando gatilhos facilitaram a localização de alterações, e várias mudanças benignas eram apenas documentais ou locais. Nosso conjunto PicoRV32 incluiu refatorações estruturais mais amplas. São condições diferentes de avaliação, que não permitem atribuir eventual diferença de desempenho apenas à habilidade dos grupos.

Uma abordagem purple team é relevante porque transforma a troca de rótulos em revisão conjunta das hipóteses de ataque e defesa. Após a classificação cega, os autores podem revelar o contrato violado e o comportamento pretendido; os avaliadores podem devolver a evidência encontrada, os casos ambíguos e as dificuldades de interpretação. O retorno de 20/20 já fecha a comparação de rótulos do AES. A ressalva de A17 permanece útil para discutir a diferença entre a intenção benigna e o cumprimento literal de R3.

Na revisão conjunta, cada decisão pode ser apresentada como uma cadeia de evidências: trecho alterado, condição relevante, efeito sobre o comportamento e regra afetada. Para AES, essa estrutura organiza os casos de corrupção de saída, exposição de chave e dependência de histórico. Para PicoRV32, permite discutir separadamente os efeitos sobre registradores, fluxo de controle, memória e sinalização. O objetivo é compreender por que uma classificação foi correta ou equivocada, além de contabilizar acertos.

3.6 Pendências da avaliação do ataque

Até esta versão, o grupo destinatário não devolveu a classificação das amostras S01-S20. A acurácia desse avaliador, os falsos positivos nas benignas e os trojans não identificados permanecem pendentes. Não atribuímos zero nem estimamos percentuais para resultados ausentes.

Quando as respostas chegarem, a comparação com o mapeamento interno permitirá calcular VP, VN, FP e FN, tomando Trojan como positivo. Acurácia será (VP+VN)/20; taxa de detecção dos trojans, VP/10; e taxa de falsos positivos, FP/10. Um falso negativo representará um trojan não reconhecido no desafio de classificação, sem demonstrar por si só eficácia operacional do ataque.

Além das métricas agregadas, o retorno permitirá analisar quais tipos de alteração foram mais difíceis de distinguir. Será especialmente útil observar se as refatorações estruturais benignas foram confundidas com trojans e se alterações dependentes de histórico ou controle passaram despercebidas. Nos casos divergentes, a discussão conjunta deve identificar a evidência usada pelo avaliador e esclarecer eventuais ambiguidades do contrato.

4 Conclusão

Produzimos um desafio com vinte variantes independentes do PicoRV32, dez deliberadamente incorretas e dez candidatas benignas, e o enviamos com IDs permutados e gabarito separado. As alterações benignas foram escolhidas para exigir análise funcional, enquanto as deliberadas cobriram aritmética, desvios, registradores, memória, reset, trap e progresso.

Na frente de detecção, a inspeção estática das vinte amostras AES identificou condições de ativação e efeitos em dez trojans e justificou dez classificações inócuas. O grupo E confirmou vinte acertos, correspondendo a 100% de acurácia nesse conjunto. A análise mostrou a utilidade de relacionar cada mudança a uma obrigação explícita, em vez de classificar apenas por aparência ou complexidade do código.

A principal lição é que a interpretação do comportamento e do contrato deve orientar a distinção entre trojans e alterações inócuas. O ciclo purple team permite transformar a revelação dos gabaritos em melhorias da documentação, das estratégias de análise e das amostras. Para concluir a avaliação do ataque produzido, faltam o retorno do outro grupo e a análise das classificações recebidas.

Dados e materiais

O repositório da atividade reúne o CSV anonimizado do grupo E, a regra de negócio, os vinte códigos extraídos e avaliacao_grupo_e.csv, em outros/aula-08-trojan. O projeto PicoRV32 contém variants/README.md, as variantes, internal/mapeamento.csv e o pacote entregue. O histórico de elaboração foi consultado para reconstruir o processo. A confirmação de 20/20 foi informada pelo grupo em 11/11/2026; a resposta ao desafio PicoRV32 ainda está pendente.

Referências

[1] YosysHQ. PicoRV32: A Size-Optimized RISC-V CPU. Código-fonte e documentação do projeto. Disponível em: https://github.com/YosysHQ/picorv32. Consulta em 11 nov. 2026.

[2] NIST. Advanced Encryption Standard (AES). FIPS 197, publicado em 2001 e atualizado em 2023. DOI: 10.6028/NIST.FIPS.197-upd1. Disponível em: https://csrc.nist.gov/pubs/fips/197/final. Consulta em 11 nov. 2026.